

DOCUMENT INFORMATION

DETAILS

Document Title	Design, Deployment, and Security Assessment of a Simulated Enterprise Infrastructure
Report Subtitle	HexaCore Technologies Pvt. Ltd. – Internal Vulnerability Assessment and Penetration Testing Report
Project Name	HexaCore Technologies Pvt. Ltd. – Simulated Enterprise Security Assessment
Document Version	Version 1.0
Prepared By	Jenifer Catherine D
Assessment Type	Web Application, Network Service, and Linux Privilege Escalation Assessment (Simulated Environment)
Document Status	Final Report

CONFIDENTIALITY STATEMENT

This report documents a cybersecurity assessment conducted within a self-built simulated enterprise environment developed for educational purposes.

The organization, infrastructure, vulnerabilities, and assessment scenarios presented in this report are fictional and were intentionally designed to demonstrate practical Vulnerability Assessment and Penetration Testing (VAPT) methodologies.

The findings, techniques, and recommendations documented in this report are intended solely for learning, skill demonstration, and cybersecurity portfolio presentation. Any resemblance to real organizations or production environments is purely coincidental.

NO	SECTION	PAGE NO
1	Executive Summary	3
2	Engagement Overview	4
3	Scope of Assessment	5
4	Assessment Environment	6
5	Assessment Methodology	9
6	Tools Used	11
7	Risk Rating Methodology	12
8	Executive Risk Summary	13
9	Detailed Findings	
9.1	Reconnaissance & Service Enumeration	15
9.2	Web Application Enumeration	17
9.3	HC-VULN-01 – Directory Listing Enabled	19
9.4	HC-VULN-02 – Sensitive Backup File Exposure	22
9.5	HC-VULN-03 – SQL Injection	25
9.6	HC-VULN-04 – Unrestricted File Upload	29
9.7	HC-VULN-05 – Anonymous FTP Access	33
9.8	HC-VULN-06 – Anonymous SMB Share with Write Access	36
9.9	HC-VULN-07 – Weak Sudo Configuration (Privilege Escalation)	39
10	Conclusion	43

1. EXECUTIVE SUMMARY

Cybersecurity threats continue to increase as organizations rely heavily on web applications, network services, and interconnected infrastructure. Identifying and addressing security weaknesses before they are exploited is a critical component of maintaining a secure environment.

This project involved the design, deployment, and security assessment of a simulated enterprise environment named HexaCore Technologies Pvt. Ltd. The environment was intentionally configured with realistic security weaknesses to replicate common vulnerabilities found in corporate infrastructures.

The objective of this Vulnerability Assessment and Penetration Testing (VAPT) project was to identify security vulnerabilities across web applications, network services, and the underlying Linux operating system. The assessment followed a structured security testing approach involving reconnaissance, service enumeration, vulnerability identification, controlled exploitation, privilege escalation testing, and remediation analysis.

During the assessment, multiple security issues were identified, including web application vulnerabilities, information disclosure issues, insecure network service configurations, and operating system privilege escalation weaknesses.

The assessment identified seven vulnerabilities with severity ratings ranging from Medium to Critical. The most significant findings included SQL Injection, Unrestricted File Upload, Anonymous SMB access with write permissions, and insecure sudo configuration allowing privilege escalation to root access.

The identified vulnerabilities demonstrate the potential impact of inadequate input validation, improper access controls, insecure service configurations, and excessive user privileges. If these weaknesses existed in a production environment, they could allow attackers to gain unauthorized access, expose sensitive information, compromise application functionality, or obtain complete control over affected systems.

This report documents the assessment methodology, identified vulnerabilities, evidence collected during testing, risk analysis, and recommended remediation measures to improve the overall security posture of the simulated enterprise environment.

2. ENGAGEMENT OVERVIEW

To develop practical Vulnerability Assessment and Penetration Testing (VAPT) skills, a simulated enterprise environment named HexaCore Technologies Pvt. Ltd. was designed and deployed using an Ubuntu Desktop (LTS) virtual machine. The environment was configured to replicate a realistic internal corporate infrastructure consisting of a web application, database server, FTP service, SMB file sharing service, and Linux operating system.

Unlike intentionally vulnerable applications such as DVWA or Metasploitable, this project involved building the environment from the ground up, configuring enterprise services, and intentionally introducing realistic security misconfigurations and application vulnerabilities. This approach provided hands-on experience in both system administration and offensive security testing while closely simulating a real-world internal VAPT engagement.

The assessment was conducted within a controlled laboratory environment for educational and professional portfolio purposes. All vulnerabilities were intentionally introduced and validated in an isolated virtual machine without impacting any production systems.

2.1 Assessment Type

This project represents an Internal Vulnerability Assessment and Penetration Testing (VAPT) exercise performed against a self-built simulated enterprise environment. The assessment focused on identifying vulnerabilities within web applications, network services, and the Linux operating system through a combination of manual testing and security tool-assisted analysis.

The assessment followed a controlled methodology encompassing reconnaissance, enumeration, vulnerability validation, privilege escalation testing, risk analysis, and remediation planning.

3. SCOPE OF ASSESSMENT

3.1 Assessment Scope

The assessment was conducted against a simulated enterprise environment developed to replicate a realistic internal corporate infrastructure. The objective was to evaluate the security posture of the deployed services by identifying, validating, and documenting common vulnerabilities through a structured Vulnerability Assessment and Penetration Testing (VAPT) process.

The assessment covered web application security, network service security, Linux system configuration, and local privilege escalation within the configured Ubuntu Desktop virtual machine.

4. ASSESSMENT ENVIRONMENT

4.1 Environment Overview

The assessment was performed within a self-built simulated enterprise environment designed to emulate a small organization's internal infrastructure. The environment was deployed using Oracle VirtualBox and consisted of a single Ubuntu Desktop virtual machine configured to host multiple enterprise services.

The virtual machine was configured to function as a multi-service host running a web application, database server, FTP service, Samba file sharing service, and Linux operating system components. Several security weaknesses were intentionally introduced to simulate common vulnerabilities encountered during enterprise security assessments.

The environment was isolated from production systems, ensuring that all testing activities were performed safely within a controlled laboratory setting.

4.2 System Configuration

Component	Configuration
Virtualization Platform	Oracle VirtualBox
Operating System	Ubuntu Desktop (LTS)
Web Server	Apache HTTP Server
Application Language	PHP
Database	MySQL
FTP Service	vsftpd
File Sharing	Samba (SMB)
Assessment Type	Internal VAPT
Environment	Simulated Enterprise Infrastructure

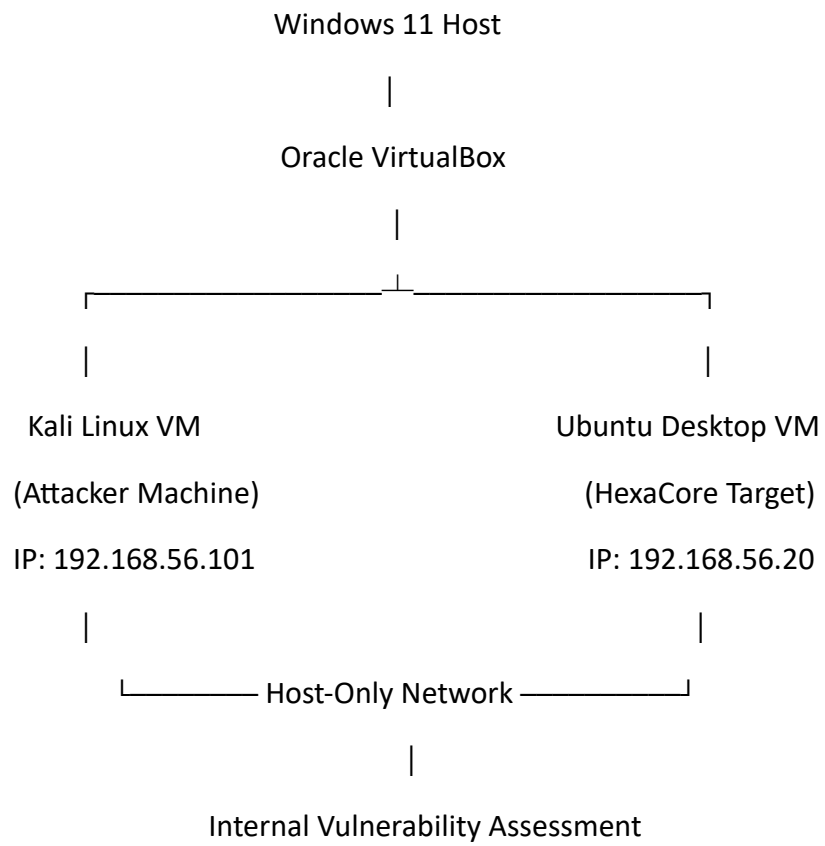
4.3 Services Configured

Service	Purpose
Apache	Hosted the vulnerable web application
PHP	Server-side application execution
MySQL	Backend database for authentication
FTP	File transfer service for security assessment
Samba (SMB)	Shared network file storage
Sudo	Linux privilege management

4.4 Network Configuration

Parameter	Value
Host Operating System	Windows 11
Virtualization Platform	Oracle VirtualBox
Attacker Machine	Kali Linux
Target Machine	Ubuntu Desktop (HexaCore Technologies)
Network Configuration	Dual Network Adapters (NAT + Host-Only Adapter)
Attacker IP Address	192.168.56.101
Target IP Address	192.168.56.20
Assessment Environment	Isolated Local Virtual Environment

4.5 Network Architecture:



5. ASSESSMENT METHODOLOGY

5.1 Methodology Overview

The Vulnerability Assessment and Penetration Testing (VAPT) was performed using a structured methodology to systematically identify, validate, and assess security weaknesses within the simulated enterprise environment.

The assessment combined manual testing techniques with industry-standard security tools to evaluate the security posture of the target system. Each identified vulnerability was validated through controlled exploitation to determine its potential impact while ensuring that all testing remained within the isolated virtual environment.

The assessment process consisted of reconnaissance, service enumeration, vulnerability identification, controlled exploitation, privilege escalation testing, risk analysis, and remediation planning.

5.2 Assessment Phases

Phase	Activities Performed
Reconnaissance	Identified the target system and gathered preliminary information.
Service Enumeration	Enumerated open ports, running services, and service versions.
Web Application Assessment	Tested the web application for information disclosure, authentication weaknesses, SQL Injection, and unrestricted file upload vulnerabilities.
Network Service Assessment	Evaluated FTP and SMB services for insecure configurations and unauthorized access.
Privilege Escalation Assessment	Reviewed local system configurations and validated privilege escalation through insecure sudo permissions.
Risk Analysis	Assessed the severity and potential impact of each identified vulnerability.
Reporting	Documented findings, supporting evidence, and remediation recommendations.

5.3 STANDARDS AND BEST PRACTICES

Although this assessment was conducted within a simulated environment, the testing methodology was aligned with widely accepted cybersecurity principles and best practices. The assessment approach was influenced by:

- OWASP Web Security Testing Guide (WSTG) – for web application security testing.
- OWASP Top 10 – for identifying common web application risks.
- PTES (Penetration Testing Execution Standard) – for structuring the penetration testing lifecycle.
- CVSS v3.1 (Common Vulnerability Scoring System) – for evaluating vulnerability severity.

These frameworks were used as guidance to ensure that the assessment followed a structured and industry-recognized approach.

6. TOOLS USED

6.1 Security Assessment Tools

Tool	Purpose
Nmap	Host discovery, port scanning, service detection and version enumeration
Gobuster	Directory and file enumeration of the web application
FTP Client	Verification of anonymous FTP access
smbclient	Enumeration and testing of SMB shares
MySQL Client	Validation of database connectivity and credentials
Linux Terminal	System enumeration and privilege escalation testing
Firefox Web Browser	Accessing and testing the web application

6.2 Supporting Utilities

Utility	Purpose
Apache HTTP Server	Hosted the vulnerable PHP web application
PHP	Server-side scripting language
MySQL	Backend database
vsftpd	FTP service
Samba	SMB file sharing service
sudo	Privilege management
Nano	Configuration file editing
Vim	Privilege escalation validation

7. RISK RATING METHODOLOGY

The severity of each identified vulnerability was evaluated using the **Common Vulnerability Scoring System (CVSS) Version 3.1** together with professional judgment based on the context of the simulated enterprise environment.

Each vulnerability was assessed by considering multiple factors, including the ease of exploitation, the level of access required, the potential impact on confidentiality, integrity, and availability (CIA), and the overall business risk posed to the target environment.

The assigned severity ratings provide a practical representation of the potential impact if the identified vulnerabilities were present in a production enterprise environment.

7.1 Severity Classification

Severity	CVSS Score	Description
Critical	9.0 – 10.0	Vulnerabilities that can result in complete system compromise or severe business impact and require immediate remediation.
High	7.0 – 8.9	Vulnerabilities that could lead to significant security compromise and should be remediated as a high priority.
Medium	4.0 – 6.9	Vulnerabilities that present moderate security risks and should be addressed in a planned remediation cycle.
Low	0.1 – 3.9	Vulnerabilities with limited security impact but that should be corrected to improve the overall security posture.
Informational	0.0	Observations or best-practice recommendations that do not represent an exploitable vulnerability.

8. EXECUTIVE RISK SUMMARY

8.1 Risk Overview

The assessment identified **seven security vulnerabilities** across the simulated enterprise environment. The findings included weaknesses affecting the web application, network services, and Linux operating system configuration. Each vulnerability was validated through controlled testing and assigned a severity rating based on the CVSS v3.1 framework and its potential impact within the simulated environment.

Three vulnerabilities were classified as **Critical**, two as **High**, and two as **Medium**. The most significant risks included SQL Injection, Unrestricted File Upload, and an insecure sudo configuration that allowed privilege escalation to root access. Collectively, these findings demonstrate how multiple security weaknesses can be chained together to significantly increase the overall risk to an organization's infrastructure if left unaddressed.

8.2 Summary of Findings

Finding ID	Vulnerability	Category	Severity
HC-VULN-01	Directory Listing Enabled	Web Server Misconfiguration	Medium
HC-VULN-02	Sensitive Backup File Exposure	Information Disclosure	High
HC-VULN-03	SQL Injection	Web Application	Critical
HC-VULN-04	Unrestricted File Upload	Web Application	Critical
HC-VULN-05	Anonymous FTP Access	Network Service	Medium
HC-VULN-06	Anonymous SMB Share with Write Access	Network Service	High
HC-VULN-07	Weak Sudo Configuration (Privilege Escalation)	Local Privilege Escalation	Critical

8.3 Severity Distribution

Severity	Number of Findings
Critical	3
High	2
Medium	2
Low	0
Total	7

9. DETAILED FINDINGS

9.1 Reconnaissance & Service Enumeration

Description

The objective of the reconnaissance phase was to identify the target host, enumerate accessible network services, and determine potential attack surfaces for further security assessment. Service discovery was performed to identify exposed ports, running services, and application versions that could be targeted during subsequent testing.

Tool Used

Tool	Purpose
Nmap	Host discovery, port scanning, service enumeration, and version detection

Command Executed

```
nmap -sC -sV -O 192.168.56.20
```

Evidence

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ nmap -sS -sV -O 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 19:26 +0530
Nmap scan report for 192.168.56.20
Host is up (0.0016s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.58 ((Ubuntu))
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
MAC Address: 08:00:27:2B:DB:28 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=7/17%OT=21%CT=1%CU=38898%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6A5A3490%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=10F%TI=Z%CI=Z%II=I
OS:%TS=20)SEQ(SP=106%GCD=1%ISR=107%TI=Z%CI=Z%TS=22)SEQ(SP=107%GCD=1%ISR=10C
OS:%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=108%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=21)SEQ(
OS:SP=FC%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW9%O2=M5B4ST11N
OS:W9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88
OS:%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4
OS:NNSNW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%W=0%A=S+F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R
OS:=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=
OS:AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=
OS:40%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID
OS:=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.32 seconds
```

Scan Results

Port	Service	Observation
21	FTP	FTP service detected
22	SSH	OpenSSH service identified
80	HTTP	Apache web server identified
139	NetBIOS	Samba service detected
445	SMB	SMB file sharing service detected

9.2 Web Application Enumeration

Description

After identifying an active HTTP service on the target system, web application enumeration was performed to identify hidden directories and files that were not directly linked from the application's user interface. The objective was to discover publicly accessible resources that could expose sensitive information or indicate insecure server configurations.

Tool Used

Tool	Purpose
------	---------

Gobuster	Directory and file enumeration of the web application
----------	---

Command Executed

```
gobuster dir -u http://192.168.56.20 -w /usr/share/wordlists/dirb/common.txt
```

Evidence

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ gobuster dir \
-u http://192.168.56.20 \
-w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.20
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 278]
admin.php (Status: 302) [Size: 0] [→ admin_login.php]
.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
assets (Status: 301) [Size: 315] [→ http://192.168.56.20/assets/]
backups (Status: 301) [Size: 316] [→ http://192.168.56.20/backups/]
css (Status: 301) [Size: 312] [→ http://192.168.56.20/css/]
documents (Status: 301) [Size: 318] [→ http://192.168.56.20/documents/]
images (Status: 301) [Size: 315] [→ http://192.168.56.20/images/]
index.php (Status: 200) [Size: 2086]
js (Status: 301) [Size: 311] [→ http://192.168.56.20/js/]
server-status (Status: 403) [Size: 278]
uploads (Status: 301) [Size: 316] [→ http://192.168.56.20/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Directories & Files Discovered

Resource	Status	Security Significance
/admin.php	302 Redirect	Administrative interface discovered
/backups/	301	Potential backup file exposure
/uploads/	301	Potential unrestricted file upload location
/documents/	301	May expose sensitive documents
/assets/	301	Static application resources
/images/	301	Static content
/css/	301	Stylesheets
/js/	301	JavaScript resources
/server-status	403	Apache status page exists but access is restricted
.htaccess, .htpasswd, .hta	403	Protected Apache configuration files

Assessment Observation

The directory enumeration identified a publicly accessible **/backups/** directory. Since backup directories frequently contain archived application files, configuration files, or database backups, the directory was selected for further investigation to determine whether sensitive information was exposed.

Accessing the discovered **/backups/** directory revealed that directory indexing was enabled, allowing its contents to be viewed without authentication. This observation resulted in the identification of **HC-VULN-01 – Directory Listing Enabled**.

9.3 HC-VULN-01 – Directory Listing Enabled

Description

Directory listing was enabled for the **/backups/** directory on the Apache web server. As a result, the web server automatically generated and displayed an index of the directory contents when accessed through a web browser.

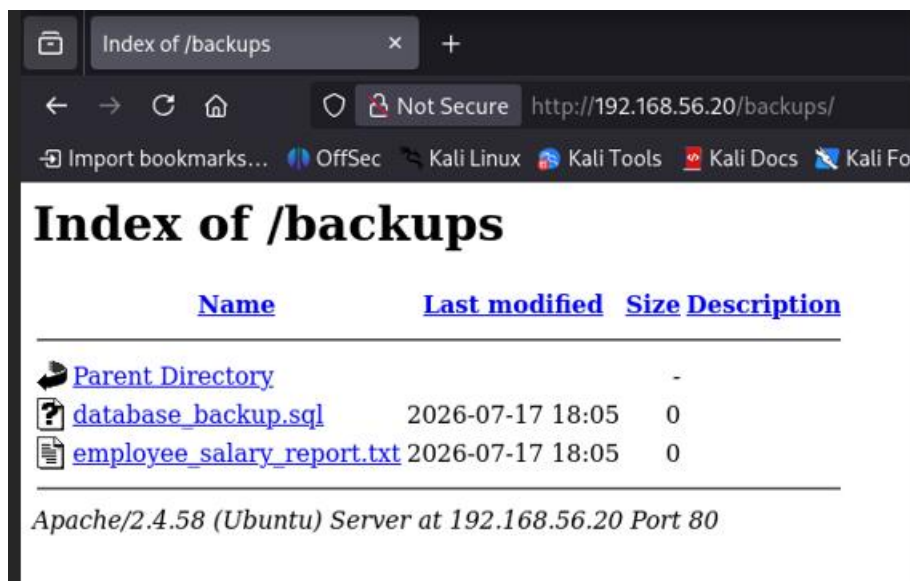
This behavior exposed the names and locations of files stored within the directory without requiring authentication. Directory listing is considered a security misconfiguration because it provides attackers with valuable information that can be used to identify sensitive files, configuration backups, source code, or other resources that should not be publicly accessible.

Validation

Following the discovery of the **/backups/** directory during web application enumeration, the directory was accessed directly through the web browser.

The server responded with an automatically generated directory index, confirming that directory browsing was enabled. No authentication or authorization controls were enforced, allowing unrestricted access to the directory contents.

Evidence



Finding Information

Field	Value
Finding ID	HC-VULN-01
Vulnerability	Directory Listing Enabled
Severity	Medium
CVSS v3.1 Base Score	5.3 (Medium)
Category	Security Misconfiguration
Affected Asset	Apache HTTP Server
Affected Resource	/backups/
CWE	CWE-548 – Exposure of Information Through Directory Listing
OWASP Top 10	A05:2021 – Security Misconfiguration

Technical Analysis

The vulnerability was caused by the Apache web server being configured with directory indexing enabled for the **/backups/** directory. When no default index page (such as index.html or index.php) was present, Apache generated an index page listing all files contained within the directory.

Such configurations expose internal file structures and often reveal backup copies, configuration files, scripts, or other sensitive resources that can assist an attacker during subsequent stages of an assessment.

Impact

The exposed directory allowed unauthenticated users to enumerate its contents, significantly increasing the amount of information available during reconnaissance. Attackers could identify backup files, application resources, or configuration files that may contain sensitive information.

Within this assessment, the exposed directory contained a backup configuration file that led directly to the discovery of the next vulnerability (**HC-VULN-02 – Sensitive Backup File Exposure**), demonstrating how information disclosure can facilitate further exploitation.

Remediation

The following remediation measures are recommended:

- Disable directory indexing by removing the **Indexes** option from the Apache configuration.
- Restrict direct access to backup and administrative directories.
- Store backup files outside the web document root.
- Apply the principle of least privilege to web-accessible resources.
- Regularly review web server configurations to identify and correct insecure settings.

9.4 HC-VULN-02: Sensitive Backup File Exposure

Description

A backup copy of the application's configuration file (config.php.bak) was found within the publicly accessible **/backups/** directory. Since the file retained its backup extension, the web server served it as a downloadable text file instead of executing it as PHP code.

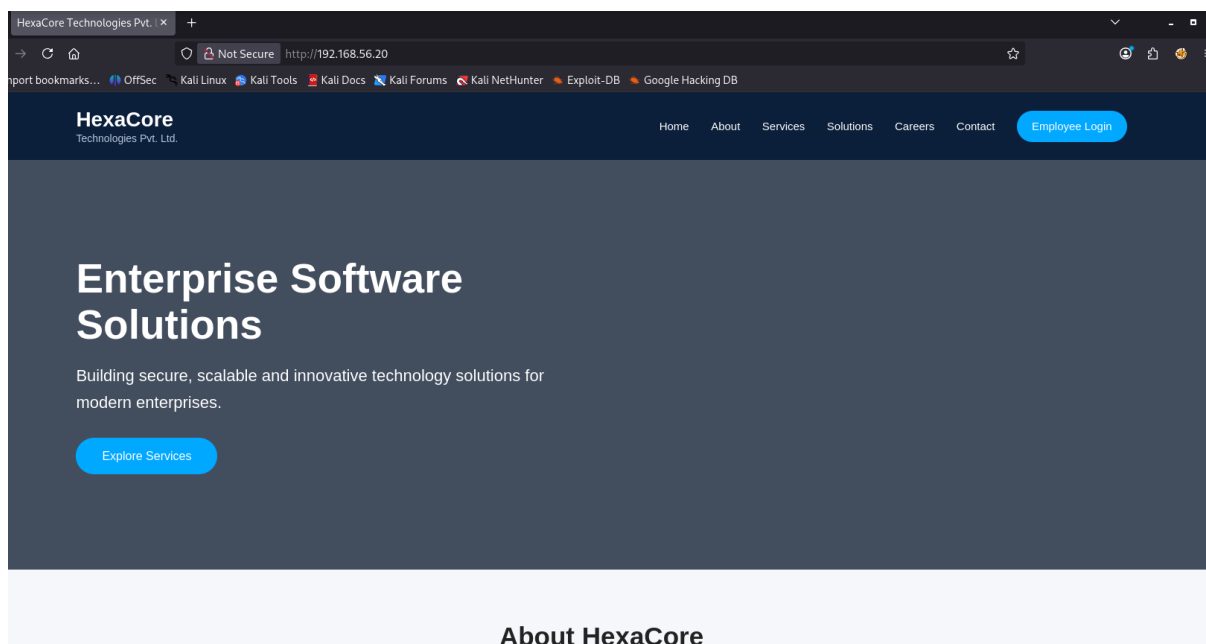
The exposed file contained sensitive configuration information, including database connection details. Disclosure of such information can significantly increase the risk of unauthorized access and facilitate further attacks against the application.

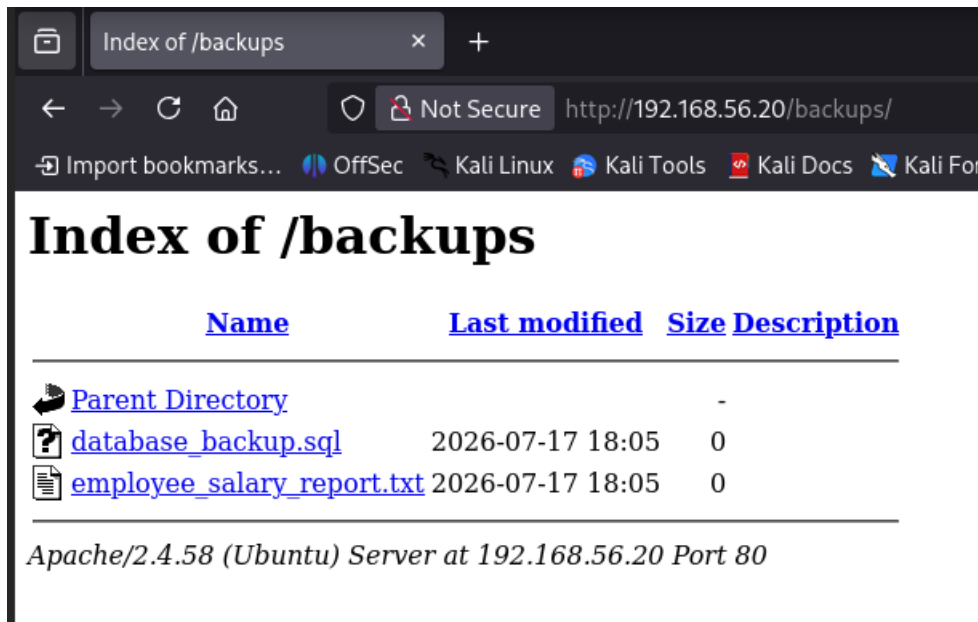
Validation

During the review of the exposed **/backups/** directory identified in **HC-VULN-01**, the file **config.php.bak** was discovered and accessed directly through the web browser.

The file contents were successfully displayed, confirming that the backup file was publicly accessible without authentication. Examination of the file revealed sensitive database configuration information.

Evidence





Finding Information

Field	Value
Finding ID	HC-VULN-02
Vulnerability	Sensitive Backup File Exposure
Severity	High
CVSS v3.1 Base Score	7.5 (High)
Category	Information Disclosure
Affected Asset	Web Application
Affected File	config.php.bak
CWE	CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor
OWASP Top 10	A05:2021 – Security Misconfiguration

Technical Analysis

The backup file contained application configuration parameters required for database connectivity, including the database host, database name, username, and password. Because the file was stored within a web-accessible directory and retained a non-executable extension, the web server returned its contents directly to the browser.

Exposure of configuration files is a common security misconfiguration and frequently provides attackers with information that can be leveraged to access backend services or support further exploitation.

Impact

The exposed backup file disclosed sensitive database connection information that could allow an attacker to authenticate to the backend database if network access were available. Even when direct database access is restricted, such information can assist in application attacks, credential reuse attempts, and further compromise of the environment.

Within this assessment, the disclosed information provided valuable insight into the application's backend configuration and supported subsequent testing of authentication mechanisms.

Remediation

The following remediation measures are recommended:

- Remove backup and temporary files from the web document root.
- Store application backups outside publicly accessible directories.
- Prevent direct web access to sensitive configuration files.
- Restrict file permissions using the principle of least privilege.
- Implement periodic reviews to identify and remove obsolete backup files.

9.5 HC-VULN-03: SQL Injection

Description

The employee login functionality was vulnerable to SQL Injection due to the application's use of dynamically constructed SQL queries without proper input validation or parameterized statements. User-supplied input was directly incorporated into SQL queries, allowing malicious SQL syntax to alter the intended query logic.

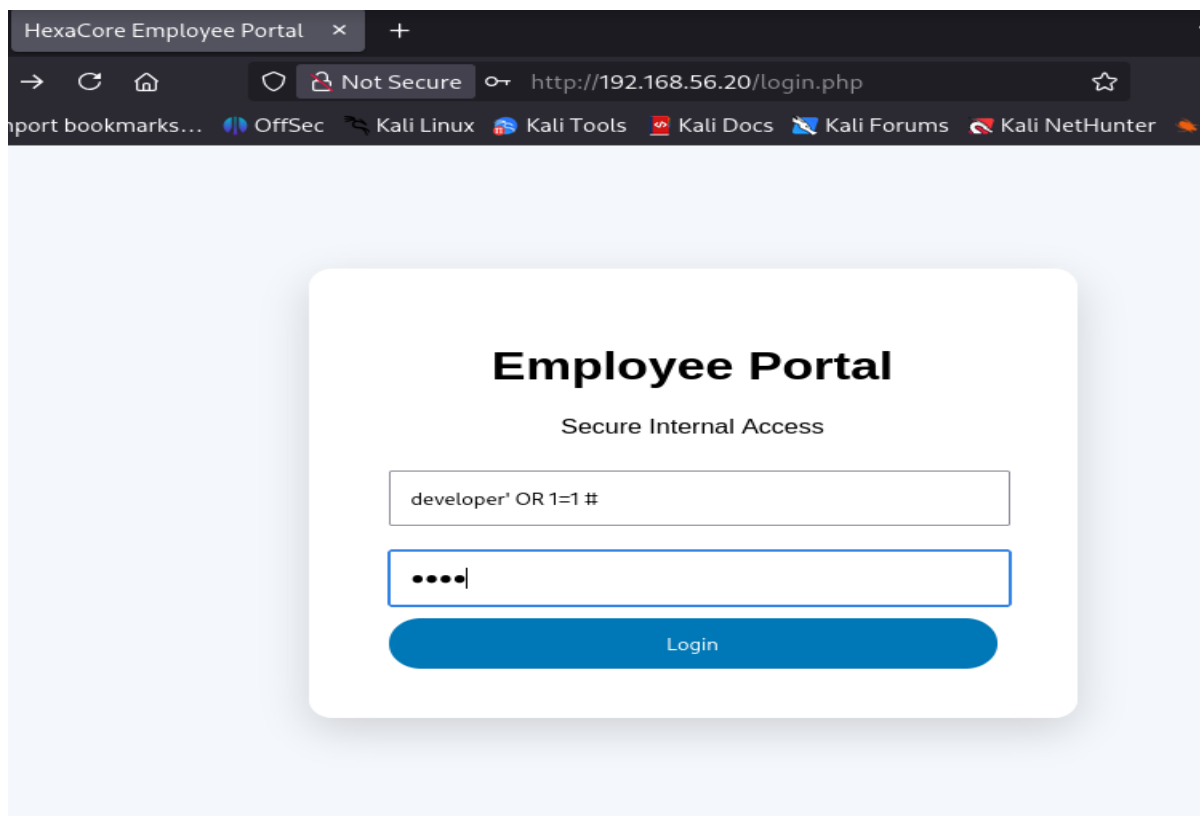
This vulnerability enabled authentication bypass, allowing unauthorized access to the application without valid credentials.

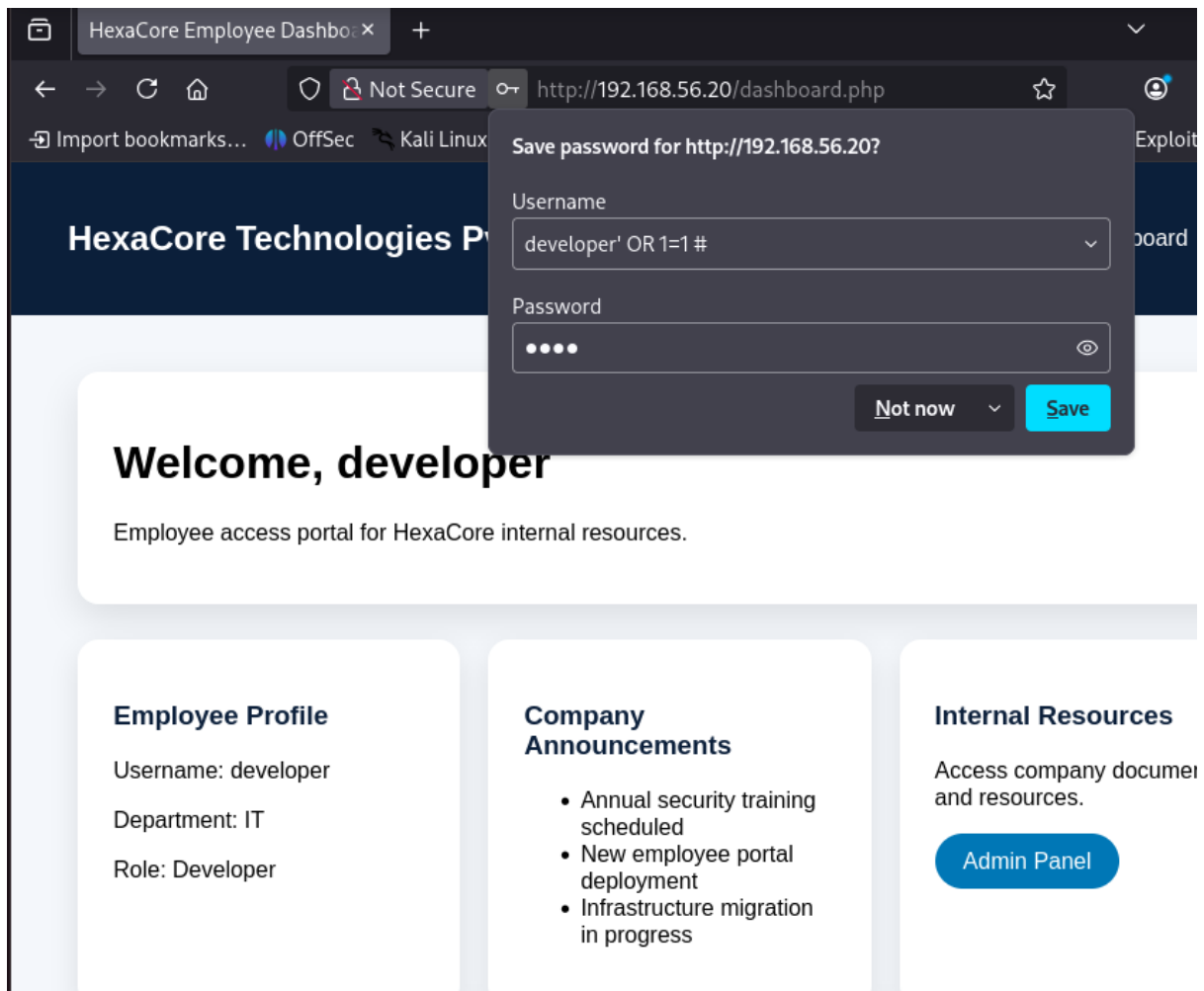
Validation

The application's login page was assessed to determine whether user input was securely processed. During testing, specially crafted SQL Injection payloads were submitted through the authentication form.

The application accepted the malicious input and successfully authenticated the session without requiring valid user credentials, confirming that the login functionality was vulnerable to SQL Injection.

Evidence





Finding Information

Field	Value
Finding ID	HC-VULN-03
Vulnerability	SQL Injection
Severity	Critical
CVSS v3.1 Base Score	9.8 (Critical)
Category	Web Application
Affected Asset	Employee Login Page
CWE	CWE-89 – Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
OWASP Top 10	A03:2021 – Injection

Technical Analysis

The vulnerability existed because the application concatenated user-controlled input directly into SQL statements without sanitization or the use of prepared statements.

This allowed SQL operators supplied by the user to modify the structure of the original query, causing the application to evaluate the injected condition rather than validating legitimate credentials.

Impact

Successful exploitation of this vulnerability allowed authentication to be bypassed without valid credentials. In a production environment, SQL Injection may also permit unauthorized disclosure of database records, modification of stored data, privilege escalation within the application, or complete compromise of the backend database depending on the permissions assigned to the application account.

Because authentication mechanisms protect access to sensitive business functionality, exploitation of this vulnerability represents a critical security risk.

Remediation

The following remediation measures are recommended:

- Use parameterized queries (prepared statements) for all database interactions.
- Validate and sanitize user input on both the client and server sides.
- Avoid constructing SQL queries through string concatenation.
- Implement secure error handling to prevent disclosure of database information.
- Apply the principle of least privilege to database accounts used by the application.
- Perform regular secure code reviews and penetration testing to identify injection vulnerabilities.

9.6 HC-VULN-04: Unrestricted File Upload

Description

The employee document upload functionality accepted user-supplied files without performing sufficient validation of file type, file extension, or upload content. As a result, executable PHP files could be uploaded to the server.

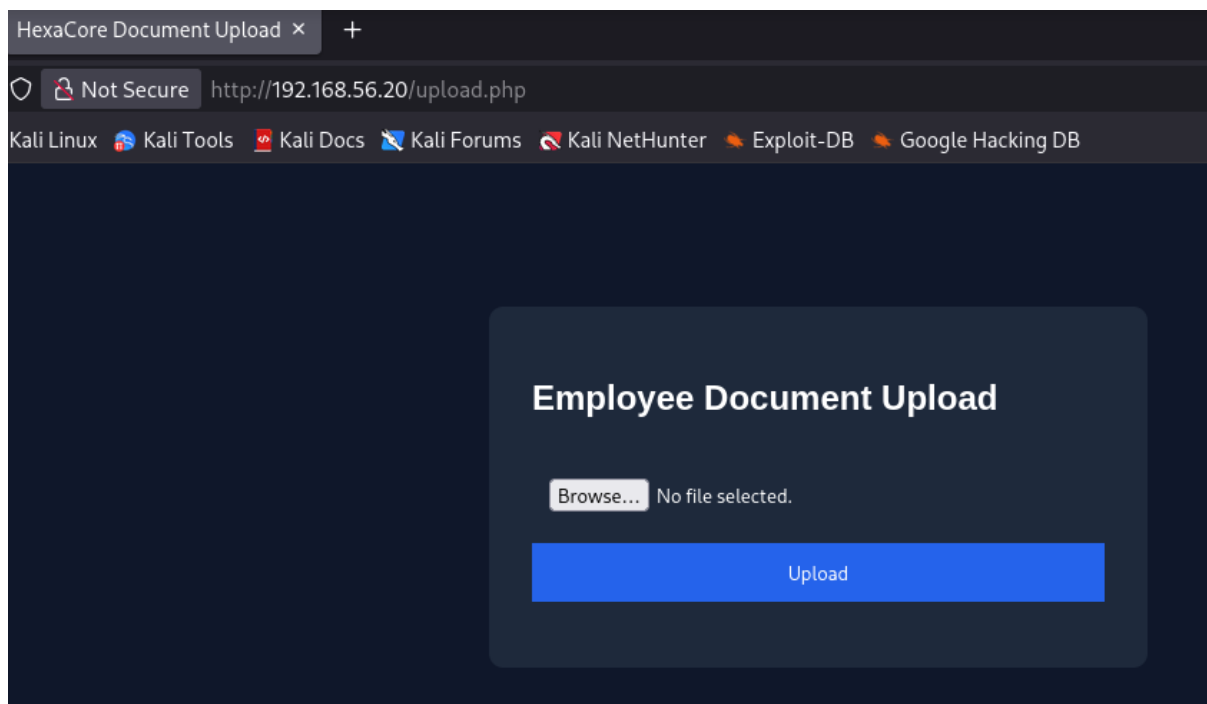
Allowing unrestricted file uploads introduces a significant security risk because attackers may upload malicious files capable of executing arbitrary code on the server if the uploaded content is stored within an executable web directory.

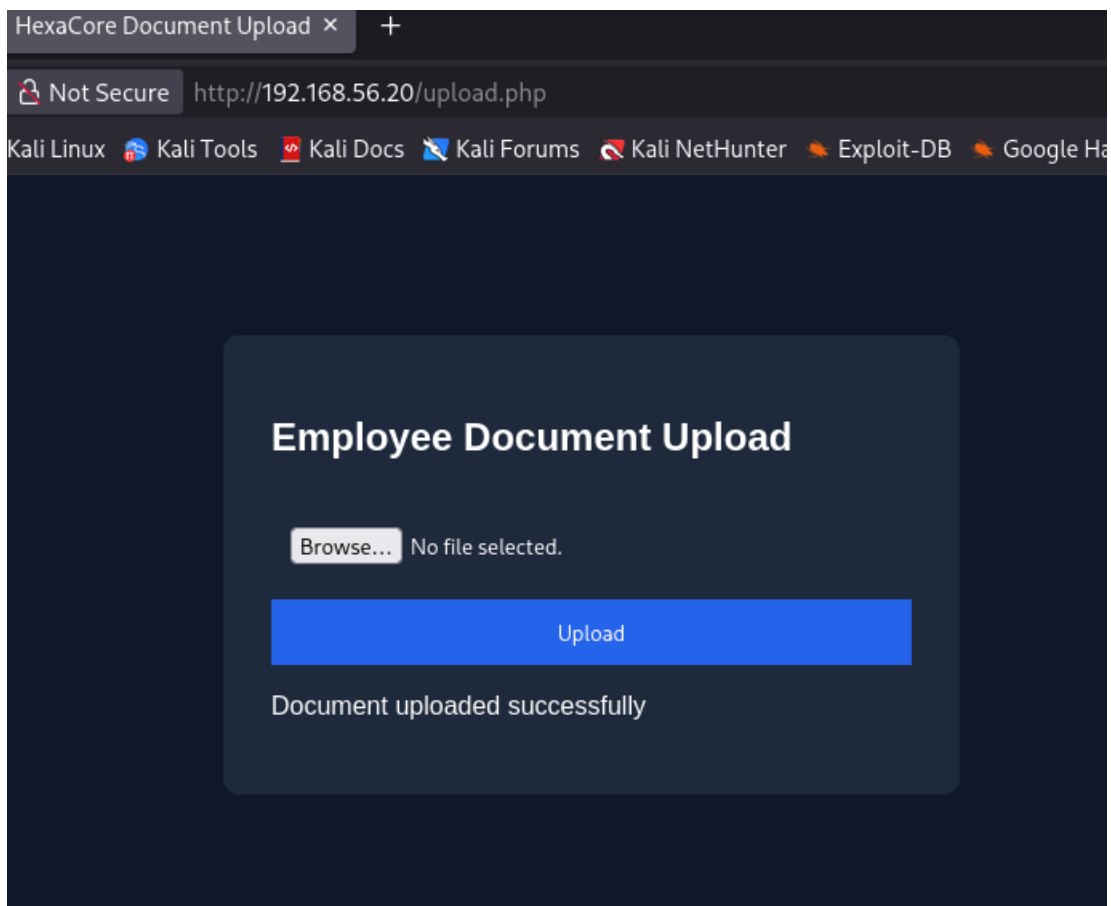
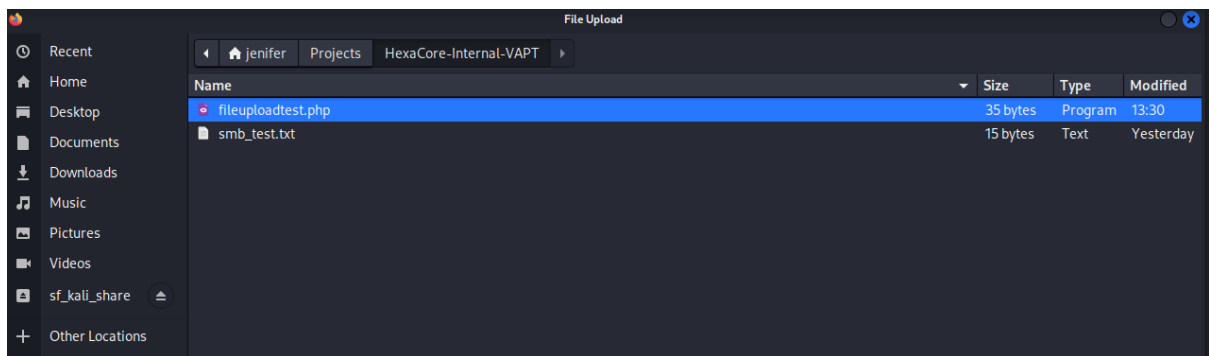
Validation

The file upload functionality was evaluated by attempting to upload a PHP file instead of an expected document type.

The application accepted the uploaded file without validating its extension or content, confirming that executable files were not adequately restricted. The successful upload demonstrated that the application lacked appropriate server-side controls to prevent potentially dangerous file types from being stored on the server.

Evidence





Finding Information

Field	Value
Finding ID	HC-VULN-04
Vulnerability	Unrestricted File Upload
Severity	Critical
CVSS v3.1 Base Score	9.8 (Critical)
Category	Web Application
Affected Asset	Employee Document Upload Functionality
CWE	CWE-434 – Unrestricted Upload of File with Dangerous Type
OWASP Top 10	A05:2021 – Security Misconfiguration

Technical Analysis

The vulnerability existed because the application accepted uploaded files without enforcing strict server-side validation of file extensions or MIME types. The absence of appropriate upload restrictions allowed files with executable extensions to be stored by the application.

In environments where uploaded files are placed within the web document root and executed by the web server, this weakness can lead to remote code execution and complete server compromise.

Impact

Successful exploitation of this vulnerability allows an attacker to upload unauthorized files to the server. If executable file types are permitted and stored within a web-accessible location, attackers may execute arbitrary server-side code, resulting in remote code execution, unauthorized access to sensitive data, or complete compromise of the application server.

Within this assessment, the successful upload of a PHP file demonstrated that the application lacked appropriate file validation controls and highlighted the potential risk associated with unrestricted file uploads.

Remediation

The following remediation measures are recommended:

- Implement strict server-side validation of file extensions and MIME types.
- Allow only approved file formats through a whitelist approach.
- Rename uploaded files using randomly generated names.
- Store uploaded files outside the web document root whenever possible.
- Disable execution permissions within upload directories.
- Enforce file size limits and perform malware scanning for uploaded content.

9.7 HC-VULN-05: Anonymous FTP Access

Description:

The FTP service was configured to allow anonymous authentication, enabling users to access the server without valid credentials. Anonymous FTP access can expose publicly accessible files and may provide attackers with information useful for reconnaissance or further exploitation.

Although anonymous access is sometimes intentionally enabled for public file distribution, it should be carefully controlled to prevent unauthorized access to sensitive resources.

Validation

The FTP service identified during network enumeration was assessed to determine whether authentication controls were properly enforced.

An anonymous login attempt was successfully accepted by the FTP server without requiring valid user credentials. Following authentication, the available files and directories were accessible, confirming that anonymous access was enabled.

Evidence

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ ftp 192.168.56.20
Connected to 192.168.56.20.
220 (vsFTPd 3.0.5)
Name (192.168.56.20:jenifer): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||15966|)
150 Here comes the directory listing.
-rw-r--r--    1 0      0      25 Jul 17 19:50 README.txt
-rw-r--r--    1 0      0      37 Jul 17 19:50 employee_handbook.txt
-rw-r--r--    1 0      0      35 Jul 17 19:50 public_notice.txt
226 Directory send OK.
ftp> █
```

Finding Information

Field	Value
Finding ID	HC-VULN-05
Vulnerability	Anonymous FTP Access
Severity	Medium
CVSS v3.1 Base Score	5.3 (Medium)
Category	Network Service
Affected Asset	vsftpd FTP Server
Service	FTP (Port 21)
CWE	CWE-306 – Missing Authentication for Critical Function
OWASP Top 10	A05:2021 – Security Misconfiguration

Technical Analysis

The FTP server was configured to permit anonymous authentication, allowing unauthenticated users to establish a connection and browse shared resources. While the assessment confirmed read access to publicly available files, anonymous FTP services increase the attack surface by exposing information without authentication.

Depending on server configuration, anonymous FTP services may also permit file uploads or downloads that could facilitate additional attacks.

Impact

Anonymous FTP access allows unauthorized users to interact with the FTP service without valid credentials. This may result in unintended disclosure of files or information that can assist attackers during reconnaissance. If write permissions are also enabled, attackers could upload malicious content or modify existing files.

In this assessment, anonymous authentication was successfully verified, demonstrating a weakness in the server's access control configuration.

Remediation

The following remediation measures are recommended:

- Disable anonymous FTP access unless it is explicitly required.
- Require authenticated user accounts for FTP access.
- Implement the principle of least privilege for FTP users.
- Restrict access using network-based controls where appropriate.
- Regularly review FTP server configurations and access logs.

9.8 HC-VULN-06: Anonymous SMB Share with Write Access

Description

The Samba file sharing service was configured to allow guest access to the **CompanyShare** network share with write permissions. As a result, unauthenticated users were able to access shared resources, view existing files, and upload new files without requiring valid credentials.

Improperly configured network shares increase the risk of unauthorized access, information disclosure, file manipulation, and the introduction of malicious content into shared business resources.

Validation

The SMB service identified during network enumeration was assessed to determine whether guest access was permitted.

Using the smbclient utility, a connection to the **CompanyShare** share was successfully established without providing valid user credentials. Once connected, existing files within the share were listed, and a test file was successfully uploaded, confirming that guest users had write permissions.

Evidence

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ smbclient -L //192.168.56.20 -N

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      CompanyShare   Disk
      IPC$           IPC       IPC Service (hexa-app-01 server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 192.168.56.20 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NE
TWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ smbclient //192.168.56.20/CompanyShare -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Fri Jul 17 19:54:34 2026
..               D            0   Fri Jul 17 19:54:34 2026
asset_inventory.txt N          19   Fri Jul 17 19:54:34 2026
test.txt         A           12   Fri Jul 17 18:13:52 2026
network_notes.txt N          31   Fri Jul 17 19:54:34 2026
hr_policy.txt    N           21   Fri Jul 17 19:54:34 2026
README.txt       N           47   Fri Jul 17 13:57:44 2026

62284540 blocks of size 1024. 46278688 blocks available
smb: \>
```

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ smbclient //192.168.56.20/CompanyShare -N
Try "help" to get a list of possible commands.
smb: \> echo "SMB Write Test" > smb_test.txt
smb: \> put smb_test.txt
putting file smb_test.txt as \smb_test.txt (1.0 kB/s) (average 1.0 kB/s)
smb: \>
```

Finding Information

Field	Value
Finding ID	HC-VULN-06
Vulnerability	Anonymous SMB Share with Write Access
Severity	High
CVSS v3.1 Base Score	8.1 (High)
Category	Network Service
Affected Asset	Samba File Sharing Service
Affected Share	CompanyShare
Service	SMB (Port 445)
CWE	CWE-732 – Incorrect Permission Assignment for Critical Resource
OWASP Top 10	A01:2021 – Broken Access Control

Technical Analysis

The Samba configuration permitted anonymous (guest) access to the shared resource while also granting write permissions. This combination of weak access control and excessive permissions allowed unauthenticated users to interact with the file share without restriction.

In enterprise environments, such misconfigurations may enable attackers to access confidential documents, modify business files, distribute malicious content, or use shared resources to facilitate lateral movement within the network.

Impact

Anonymous write access to a network share allows unauthorized users to access and modify shared content without authentication. Attackers may upload malicious files, overwrite legitimate documents, or use the shared location to distribute malware within an organization.

During this assessment, guest access and file upload capabilities were successfully verified, demonstrating insufficient access control on the SMB service.

Remediation

The following remediation measures are recommended:

- Disable guest access for SMB shares unless explicitly required.
- Require authenticated user accounts for access to shared resources.
- Apply the principle of least privilege when assigning share permissions.
- Restrict write access to authorized users only.
- Periodically review Samba configurations and file share permissions.
- Enable auditing and logging of SMB access to detect unauthorized activity.

9.9 HC-VULN-07: Weak Sudo Configuration (Privilege Escalation)

Description

The assessment identified an insecure sudo configuration that granted the low-privileged **developer** user passwordless (NOPASSWD) permission to execute the `/usr/bin/vim` binary with root privileges.

Since vim is an interactive application capable of spawning a shell, the assigned sudo permission allowed privilege escalation from a standard user account to the root user. As a result, an attacker who compromises the **developer** account could obtain full administrative control of the operating system without exploiting any software vulnerability.

Validation

Local privilege escalation testing was performed after establishing an SSH session to the target system using the low-privileged developer account.

The assigned sudo permissions were enumerated using the `sudo -l` command, which revealed that the user was permitted to execute the `/usr/bin/vim` binary as the root user without entering a password (NOPASSWD).

Using the permitted binary, shell escape functionality available within vim was used to obtain a root shell successfully. The privilege escalation was verified by confirming that commands were executed with root privileges.

Evidence

```
(jenifer@kali)-[~/Projects/HexaCore-Internal-VAPT]
$ ssh developer@192.168.56.20
developer@192.168.56.20's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 7.0.0-28-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

12 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

developer@hexa-app-01:~$ sudo -l
Matching Defaults entries for developer on hexa-app-01:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User developer may run the following commands on hexa-app-01:
    (ALL) NOPASSWD: /usr/bin/vim
developer@hexa-app-01:~$
```

```
last login: Fri Jul 27 20:10:13 2024 from 192.168.56.102
developer@hexa-app-01:~$ sudo -l
Matching Defaults entries for developer on hexa-app-01:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User developer may run the following commands on hexa-app-01:
    (ALL) NOPASSWD: /usr/bin/vim
developer@hexa-app-01:~$ sudo vim -c '!/bin/bash'

root@hexa-app-01:/home/developer# whoami
root
root@hexa-app-01:/home/developer# id
uid=0(root) gid=0(root) groups=0(root)
root@hexa-app-01:/home/developer#
```


Finding Information

Field	Value
Finding ID	HC-VULN-07
Vulnerability	Weak Sudo Configuration (Privilege Escalation)
Severity	Critical
CVSS v3.1 Base Score	9.8 (Critical)
Category	Local Privilege Escalation
Affected Asset	Ubuntu Desktop System
Affected Component	Sudo Configuration
CWE	CWE-250 – Execution with Unnecessary Privileges
OWASP Top 10	A05:2021 – Security Misconfiguration

Technical Analysis

The vulnerability resulted from an overly permissive sudo configuration that granted the **developer** user unrestricted execution of the vim binary with root privileges.

Although vim is primarily a text editor, it includes built-in shell escape functionality that allows users to execute operating system commands. When executed with elevated privileges through sudo, this capability enables a standard user to spawn a root shell without authentication.

This issue is a security misconfiguration rather than a flaw in the operating system. Improper assignment of sudo permissions to interactive binaries significantly increases the risk of privilege escalation and complete system compromise.

Impact

Successful exploitation of this vulnerability resulted in full administrative (root) access to the target system. With root privileges, an attacker can execute arbitrary commands, modify or delete system files, create privileged user accounts, disable security controls, access sensitive information, and maintain persistent access to the system.

Within this assessment, successful privilege escalation demonstrated complete compromise of the operating system, representing the highest level of impact identified during the engagement.

Remediation

The following remediation measures are recommended:

- Review and restrict sudo permissions assigned to non-administrative users.
- Avoid granting NOPASSWD access to interactive applications such as vim, less, nano, or other binaries capable of executing shell commands.
- Apply the principle of least privilege when configuring sudo policies.
- Regularly audit the /etc/sudoers file and included configuration files to identify excessive permissions.
- Monitor privileged command execution through centralized logging and security monitoring solutions.
- Conduct periodic privilege escalation assessments to identify insecure privilege assignments before deployment.

10. CONCLUSION

This Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted against a self-built simulated enterprise environment representing **HexaCore Technologies Pvt. Ltd.** The objective of the assessment was to identify, validate, and document security weaknesses across the web application, network services, and operating system using a structured and industry-recognized penetration testing methodology.

The assessment commenced with reconnaissance and service enumeration, followed by web application testing, network service evaluation, and local privilege escalation testing. Throughout the engagement, **seven security vulnerabilities** were successfully identified and validated, ranging from security misconfigurations and information disclosure issues to critical web application vulnerabilities and privilege escalation.

Among the identified findings, **SQL Injection**, **Unrestricted File Upload**, and **Weak Sudo Configuration** were classified as **Critical** due to their potential to enable unauthorized access, arbitrary code execution, and complete system compromise. Additional findings, including **Sensitive Backup File Exposure**, **Anonymous SMB Share with Write Access**, **Anonymous FTP Access**, and **Directory Listing Enabled**, demonstrated how configuration weaknesses can expose sensitive information and significantly increase the organization's attack surface.

The assessment concluded with the successful demonstration of privilege escalation from a low-privileged user account to the root user through an insecure sudo configuration. This highlighted how multiple vulnerabilities, when combined, can create an effective attack path leading to complete system compromise, emphasizing the importance of secure configuration management, defense-in-depth, and continuous security assessments.

Overall, this assessment demonstrates the complete lifecycle of a Vulnerability Assessment and Penetration Testing engagement—from planning and environment preparation to reconnaissance, enumeration, vulnerability identification, exploitation, privilege escalation, risk assessment, and remediation planning. It reflects practical experience in conducting security assessments using industry-standard tools and methodologies while producing professional technical documentation aligned with common enterprise reporting practices.